

Vaultwarden Hardening — Attack Surface Reduction

Frank Santos — mystikal.dev | July 7, 2026

Session Summary

Task	Status
Removed vim, libaom3, libheif1, libde265 + deps (43.6MB)	Done
Removed Go compiler, gcc, g++, build tools (~700MB)	Done
Removed xcaddy build tool (4.5MB)	Done
Removed /usr/local/go workspace (253MB)	Done
Disabled SSH (port 22)	Done
Disabled Postfix/SMTP (port 25)	Done
Fixed locale warnings (locale-gen en_US.UTF-8)	Done
auditd — not applicable (LXC kernel limitation)	N/A
Total disk space freed: ~1GB	Done

1. Attack Surface Reduction — Package Removal

1.1 Unnecessary Packages Identified

Wazuh CVE scan identified vulnerable packages that had no legitimate purpose on a password manager container:

Package	Reason for Removal
vim-tiny, vim-common	Text editor — not needed, nano is used instead. Multiple CVEs in vim.
libaom3	AV1 video codec — no video processing on this container.
libheif1	HEIF image decoder — no image processing needed.
libde265-0	H.265 video codec — no video processing needed.
golang, gcc, g++	Build tools — Caddy was already compiled. Build environments should never be in production environments.
xcaddy	Caddy build tool — no longer needed after Caddy binary was compiled.
libx11, libxcb, libxdmcp	X11 display libraries — no GUI on a headless container.

1.2 Removal Commands

```
apt purge vim-tiny vim-common libaom3 libheif1 libde265-0 -y && apt autoremove -y
apt purge golang golang-1.19 golang-1.19-doc golang-1.19-go golang-1.19-src golang-doc
golang-go golang-src -y && apt autoremove -y
apt purge xcaddy -y
rm -rf /usr/local/go /root/go
```

1.3 Key Principle — Build vs Runtime

Compilers (gcc, go) are needed to build software but must never exist on production systems. If an attacker gains access to a container with gcc installed, they can compile malicious code directly on the server. Build elsewhere, copy the binary, keep production clean.

2. Service Hardening — Disable Unnecessary Services

2.1 Port Audit — Before

Port	Service	Needed
8080	Vaultwarden (localhost)	Yes
2019	Caddy admin API (localhost)	Yes
443	Caddy HTTPS	Yes
80	Caddy HTTP redirect	Yes
22	SSH (sshd)	No — pct enter used instead
25	SMTP (Postfix)	No — no email functionality needed

2.2 Disable SSH

```
systemctl stop ssh && systemctl disable ssh
```

Access via pct enter 102 from Proxmox host — SSH not needed. Disabling removes a brute force attack vector on the Servers VLAN.

2.3 Disable Postfix

```
systemctl stop postfix && systemctl disable postfix
```

No mail functionality needed on a password manager container.

2.4 Port Audit — After

```
ss -tlnp
```

Port	Service	Binding
8080	Vaultwarden	localhost only
2019	Caddy admin API	localhost only
443	Caddy HTTPS	0.0.0.0
80	Caddy HTTP	0.0.0.0

3. LXC Limitations — auditd

auditd requires kernel-level audit subsystem access which is not available inside LXC containers, even privileged ones. The kernel audit subsystem is controlled at the Proxmox host level.

CIS checks 33245-33272 (audit logging) are marked Not Applicable for LXC deployments. Wazuh itself provides compensating controls — file integrity monitoring (syscheckd) and log collection (logcollector) cover similar ground.

4. Next Steps

- Install Wazuh agents on CT103 (Homepage) and pve1 (Proxmox host)
- Configure OPNsense syslog to forward firewall logs to Wazuh
- Add wazuh.mystikal.dev subdomain to Caddy
- SSH hardening — configure `/etc/ssh/sshd_config` even though SSH is disabled (fixes CIS checks)
- Password policies — install `libpam-pwquality` and configure complexity rules
- Fix locale warnings permanently — `dpkg-reconfigure locales`